

**CANDIDATO:**

FREDDY ANDRES GORDILLO CORDOVA

@FREDIIAN

2026-09-29

## Introducción a la propuesta arquitectónica

Antes de definir la arquitectura, los diagramas y la infraestructura tecnológica, es necesario partir de una premisa fundamental: la solución debe responder primero a las necesidades reales del negocio.

Actualmente existen variables que todavía deben ser levantadas o validadas con mayor detalle, como la cantidad esperada de clientes, el volumen transaccional, los sistemas existentes y sus restricciones, las capacidades del equipo de desarrollo y operaciones, los niveles de servicio requeridos, el presupuesto disponible, los requisitos regulatorios y las proyecciones de crecimiento.

Estas variables pueden cambiar de forma importante una decisión arquitectónica. Por esta razón, la propuesta presentada debe considerarse una arquitectura de referencia, construida sobre los requisitos disponibles y preparada para evolucionar a medida que se obtenga mayor información del negocio y de la operación.

El objetivo no debe ser diseñar desde el inicio una plataforma excesivamente compleja pensando en un crecimiento hipotético a muy largo plazo. La arquitectura debe ser proporcional al problema actual, sostenible económicamente y operable por el equipo disponible, pero al mismo tiempo debe permitir crecer sin requerir un rediseño completo cuando aumenten los clientes, las transacciones o los servicios.

Para lograrlo, la arquitectura debe diseñarse de manera evolutiva, modular y orientada al dominio del negocio. En lugar de organizar la solución únicamente alrededor de tecnologías, bases de datos o aplicaciones, es recomendable estructurarla alrededor de capacidades de negocio claramente identificadas, por ejemplo: Clientes, Cuentas, Transferencias, Pagos, Movimientos, Notificaciones, Seguridad, Autenticación, Fraude y Cumplimiento.

Este enfoque puede apoyarse en Domain-Driven Design (DDD) para identificar los dominios y subdominios del negocio, definir límites claros mediante Bounded Contexts y reducir el acoplamiento entre componentes. Cada servicio debe tener una responsabilidad claramente relacionada con una capacidad del negocio y evitar convertirse en un servicio genérico que concentre múltiples responsabilidades.

También es recomendable utilizar prácticas de Business Capability Mapping para relacionar los objetivos estratégicos de la entidad con las capacidades que debe soportar la plataforma. Esto permite que las decisiones tecnológicas puedan justificarse a partir del negocio y no únicamente desde una perspectiva técnica.

Para el levantamiento y gestión de requisitos puede utilizarse BABOK, complementándolo con historias de usuario, casos de uso y criterios de aceptación. Los requisitos no funcionales deben analizarse mediante atributos de calidad como disponibilidad, seguridad, rendimiento, escalabilidad, resiliencia, mantenibilidad, observabilidad y recuperación ante desastres.

Desde el punto de vista arquitectónico, puede utilizarse el modelo C4 para documentar progresivamente la solución mediante diagramas de contexto, contenedores y componentes. Las principales decisiones arquitectónicas deberán registrarse mediante Architecture Decision Records (ADR), documentando el problema, las alternativas evaluadas, la decisión tomada y sus principales consecuencias.

Para el diseño de los servicios se recomienda favorecer principios como alta cohesión, bajo acoplamiento, separación de responsabilidades y autonomía de los servicios\*\*. Cuando exista una capacidad de negocio suficientemente independiente, esta podrá evolucionar como un servicio separado. Sin embargo, no todo componente necesita convertirse en un microservicio; la granularidad debe justificarse de acuerdo con la complejidad del dominio, el volumen de transacciones, la autonomía requerida y la capacidad operativa del equipo.

También pueden aplicarse patrones como API Gateway, eventos de dominio, mensajería asíncrona, Outbox Pattern, Idempotencia, Circuit Breaker, Retry con backoff, Saga y CQRS únicamente cuando exista una necesidad concreta que los justifique. La arquitectura debe evitar incorporar patrones únicamente por tendencia tecnológica.

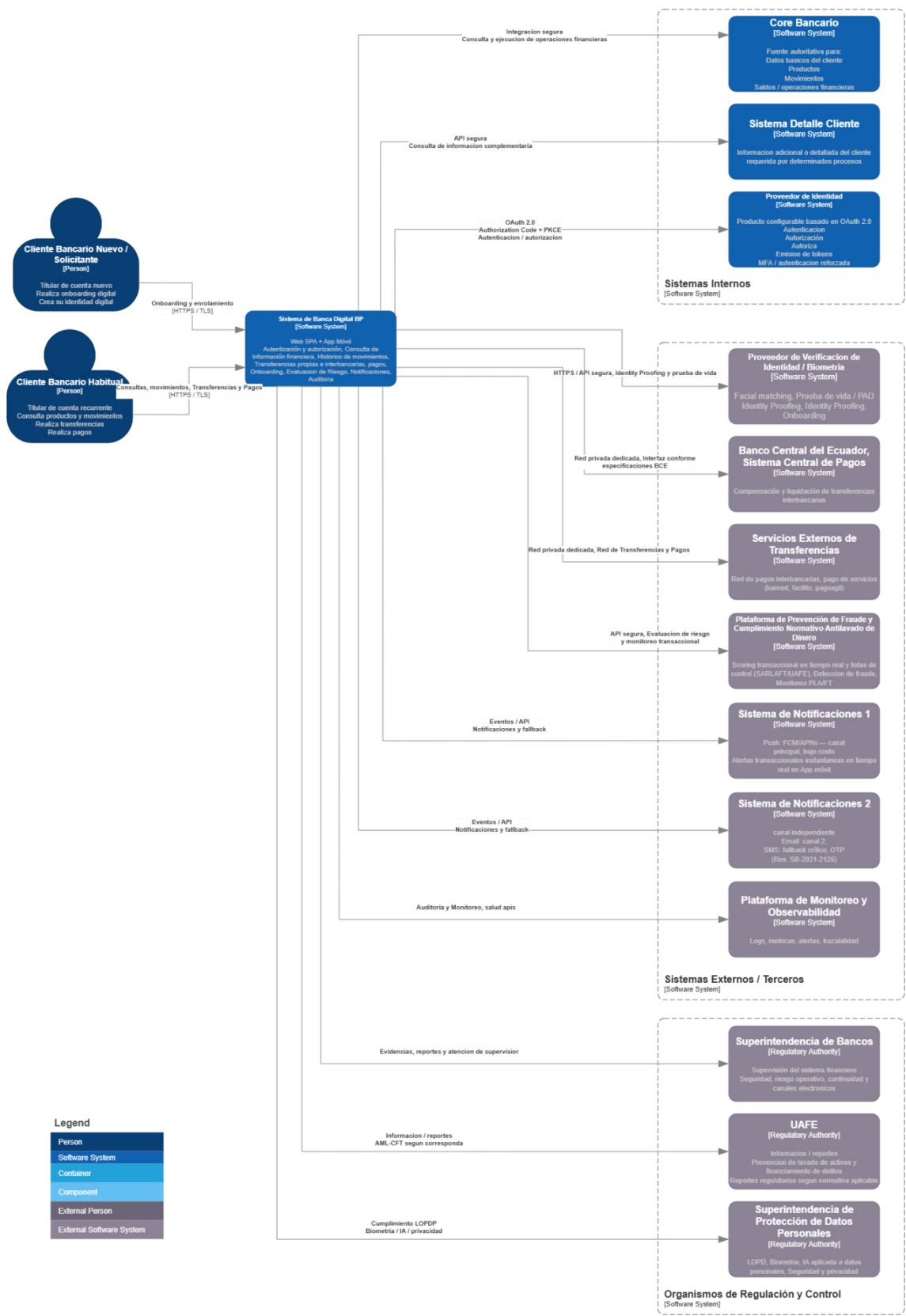
De forma complementaria, las prácticas de DevOps, CI/CD, Infrastructure as Code, observabilidad y automatización de pruebas deben integrarse desde el diseño para reducir riesgos durante la evolución de la plataforma y facilitar despliegues frecuentes, seguros y repetibles.

El dimensionamiento de infraestructura y las decisiones relacionadas con escalabilidad deberán sustentarse progresivamente mediante métricas reales, pruebas de carga, análisis de capacidad, comportamiento transaccional, crecimiento del negocio, costos de infraestructura y objetivos de nivel de servicio definidos mediante SLA, SLI y SLO.

De esta manera, la arquitectura propuesta busca alcanzar un equilibrio entre las necesidades actuales y la capacidad de crecimiento futuro. El objetivo no es construir desde el primer día la arquitectura más compleja posible, sino una solución segura, resiliente, mantenible y alineada con el negocio, que pueda evolucionar de forma controlada conforme aumenten la demanda y las capacidades de la organización.

Bajo estos principios, los siguientes diagramas presentan la arquitectura propuesta desde diferentes niveles de abstracción, comenzando por el contexto del negocio y avanzando progresivamente hacia los contenedores, componentes, servicios e infraestructura tecnológica.

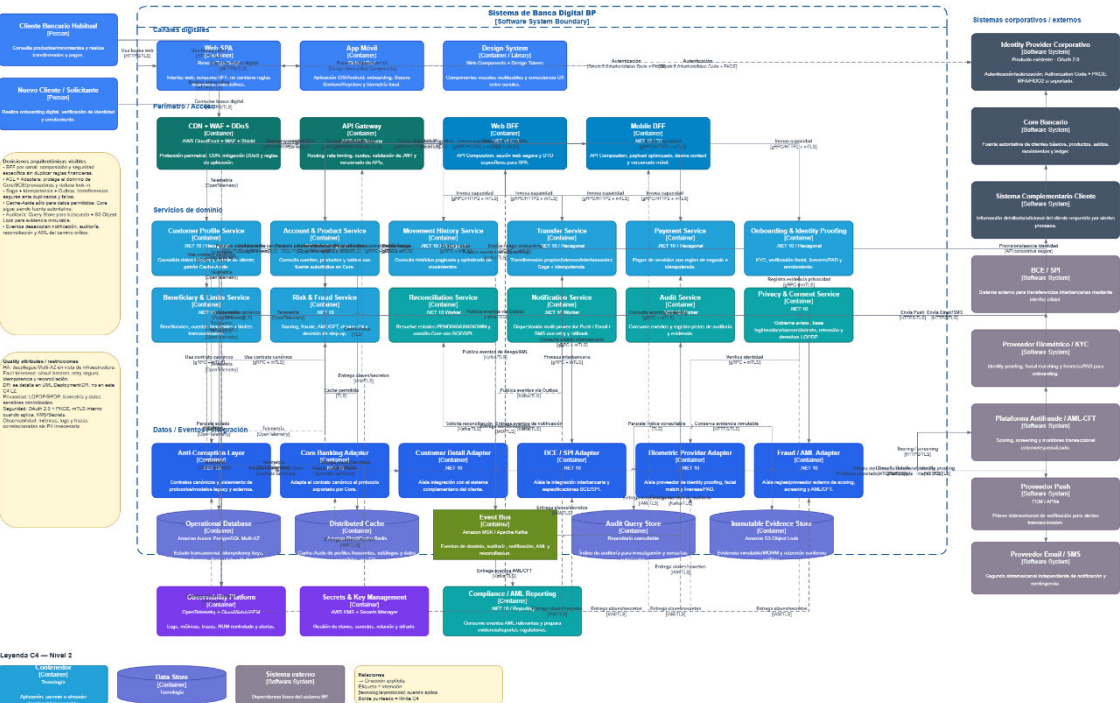
# DIAGRAMA C4 DE NIVEL 1



## DIAGRAMA C4 DE NIVEL 2

## C4 Nivel 2 — Container Diagram · Sistema de Banca Digital BP

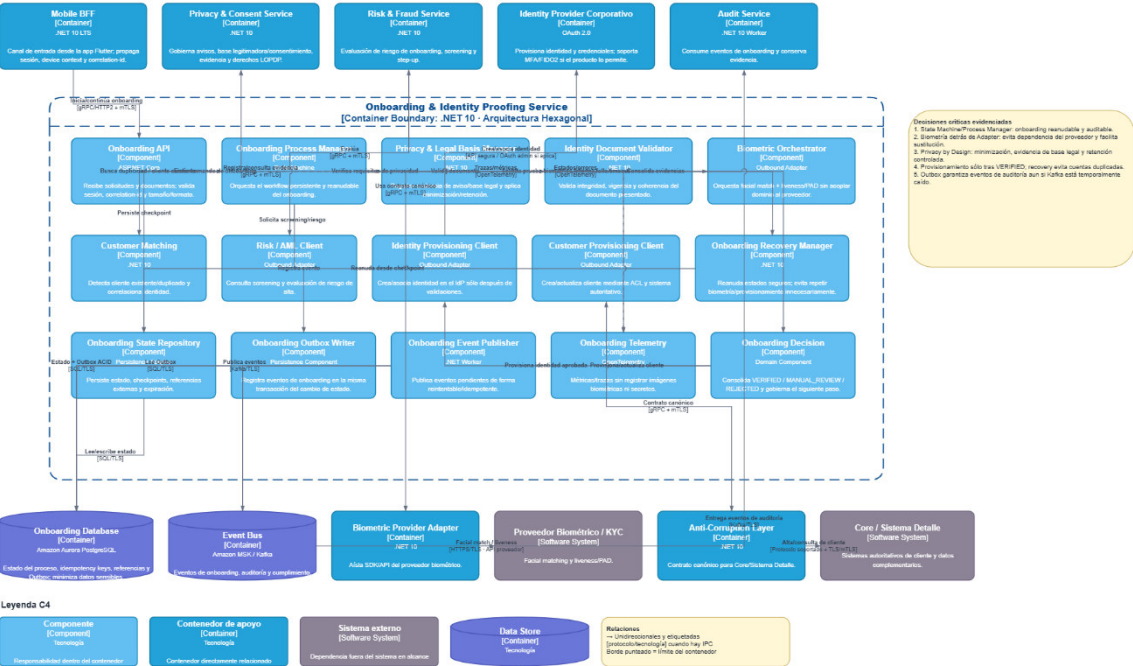
Lista técnica de aplicaciones, servicios, datos, mensajería e integraciones. Fondo transparente. AWS: arquitectura desacoplada y orientada a dominios.



# DIAGRAMA C4 DE NIVEL 3

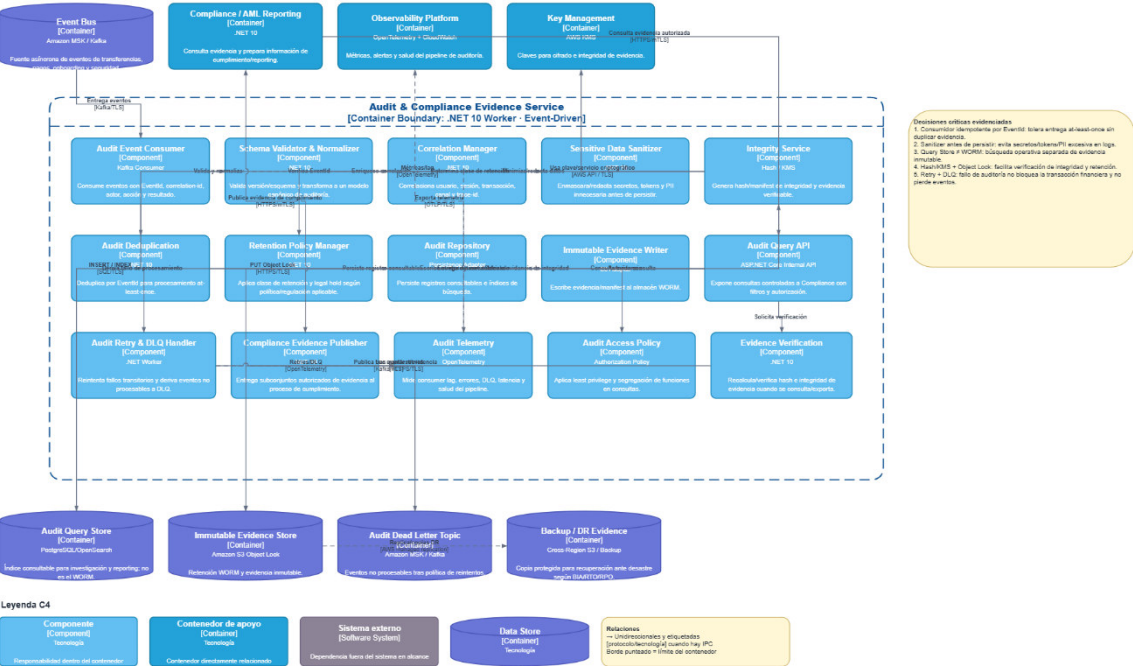
## C4 Nivel 3 — Component Diagram · Onboarding & Identity Proofing Service

Scope: un único contenedor · Alta digital, identidad, biometría, privacidad, recuperación e integración KYC



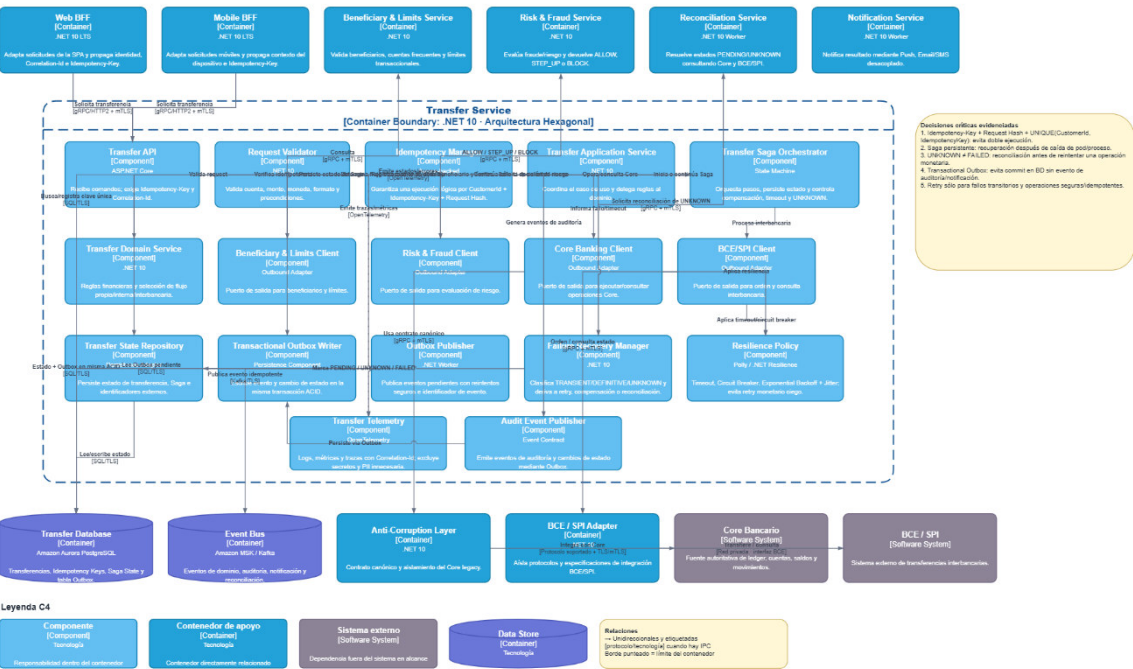
## C4 Nivel 3 — Component Diagram · Audit & Compliance Evidence Service

Scope: un único contenedor · Trazabilidad, integridad, minimización de datos y evidencia Inmutable



C4 Nivel 3 — Component Diagram · Transfer Service

Scope: un único contenedor · Componentes responsables de idempotencia, consistencia distribuida y recuperación ante fallos





| Decisión                   | Implementación                                                          | Justificación arquitectónica                                               |
|----------------------------|-------------------------------------------------------------------------|----------------------------------------------------------------------------|
| <b>Alta disponibilidad</b> | EKS + Aurora + Redis + MSK distribuidos Multi-AZ                        | Evita depender de una única AZ y permite continuidad ante fallo de nodos   |
| <b>Auto-healing</b>        | Kubernetes health probes + rescheduling + HPA                           | Pods fallidos pueden sustituirse automáticamente y capacidad puede escalar |
| <b>Fault isolation</b>     | Subredes privadas + servicios desacoplados + Kafka                      | Limita propagación de fallos                                               |
| <b>Core protegido</b>      | ACL + red privada + Direct Connect/enlace privado + VPN de contingencia | El Core nunca queda directamente expuesto a Internet                       |

| <b>Decisión</b>              | <b>Implementación</b>                            | <b>Justificación arquitectónica</b>                                       |
|------------------------------|--------------------------------------------------|---------------------------------------------------------------------------|
| <b>DR</b>                    | Segunda región en Warm Standby                   | Balance entre recuperación rápida y costo                                 |
| <b>Datos transaccionales</b> | Aurora Multi-AZ                                  | Persistencia ACID del estado de la banca digital                          |
| <b>Clientes frecuentes</b>   | Redis Cache-Aside                                | Reduce llamadas repetitivas sin convertir el caché en fuente autoritativa |
| <b>Eventos</b>               | MSK/Kafka                                        | Desacopla auditoría, notificaciones, AML y procesos secundarios           |
| <b>Auditoría</b>             | Audit DB + S3 Object Lock                        | Separa consulta operativa de evidencia inmutable                          |
| <b>Secretos</b>              | Secrets Manager + KMS                            | Evita secretos en código/imagen/configuración                             |
| <b>Observabilidad</b>        | OpenTelemetry + CloudWatch/APM                   | Logs, métricas y trazas correlacionadas                                   |
| <b>Seguridad de red</b>      | WAF + Shield + SG/NACL + egress controlado       | Defensa en profundidad                                                    |
| <b>Supply chain</b>          | CI/CD + scanning + imágenes firmadas + ECR + IaC | Despliegues repetibles, auditables y automatizados                        |
| <b>Conectividad BCE</b>      | Red privada dedicada según especificación BCE    | Aísla el canal de pagos interbancarios                                    |
| <b>Proveedores externos</b>  | Egress controlado por firewall/NAT               | Los microservicios privados no necesitan IP pública                       |

# Especificación de requisitos de banca por internet BP

*Requisitos funcionales y no funcionales*

*Análisis de negocio con BABOK y estructura basada en ISO IEC IEEE 29148*

Este documento establece la base de requisitos para diseñar y evaluar la banca digital BP. Vincula el ejercicio práctico con las necesidades del negocio, las restricciones de integración y los controles regulatorios relevantes para un banco ecuatoriano.

La solución debe permitir consultas, transferencias y pagos desde una SPA y una aplicación móvil, reutilizar los sistemas corporativos y sostener seguridad, trazabilidad y continuidad de extremo a extremo. Los valores de servicio propuestos requieren aprobación de BP antes de convertirse en compromisos contractuales.

| Control documental      | Valor                                                                      |
|-------------------------|----------------------------------------------------------------------------|
| Código                  | BP SRS 001                                                                 |
| Versión y fecha         | 1.0 • 29 de septiembre de 2026 • Ecuador                                   |
| Estado                  | Especificación para revisión y aprobación                                  |
| Propietario             | BP • Responsable del producto de banca digital                             |
| Elaboración             | Propuesta de análisis de requisitos para el ejercicio de arquitectura      |
| Revisores previstos     | Negocio, Arquitectura, Seguridad, DPD, Cumplimiento, Riesgos y Operaciones |
| Aprobación              | Patrocinador y responsables de control • pendiente                         |
| Clasificación propuesta | Uso interno • ejercicio de selección                                       |

**Base de uso**

La estructura sigue prácticas de ingeniería de requisitos de ISO/IEC/IEEE 29148:2018. No constituye una certificación ISO. BABOK se aplica como cuerpo de conocimiento adaptable, no como una metodología prescriptiva ni como una certificación del documento. [S03–S04]

# 1 Alcance y criterios de interpretación

## Alcance del producto

Incluye banca web y móvil, identidad, onboarding facial, datos básicos y detallados, histórico, transferencias, pagos, notificaciones, auditoría, persistencia para consultas frecuentes e integración con Core, sistema de detalle y terceros. Se consideran los procesos de soporte que permiten operar y demostrar los controles.

## Alcance regulatorio

Se adopta como supuesto que BP es un banco privado supervisado por la Superintendencia de Bancos. Las normas SEPS no sustituyen este régimen. La matriz cubre las familias normativas que afectan a esta solución; el cumplimiento institucional completo también incluye materias prudenciales, contables, tributarias y societarias fuera del canal digital. No equivale a un inventario exhaustivo de todas las normas de una entidad bancaria.

## Jerarquía de fuentes

| Clave | Uso                                                                                                |
|-------|----------------------------------------------------------------------------------------------------|
| E     | Exigencia expresa del ejercicio original S01. Conserva su alcance y obligatoriedad.                |
| N     | Necesidad derivada del marco normativo. Su implementación se valida con Legal, DPD o Cumplimiento. |
| D     | Requisito derivado para completar un flujo o controlar un riesgo. Requiere validación de negocio.  |
| P     | Propuesta de diseño, métrica o práctica. No se atribuye al ejercicio ni a una ley.                 |

S01 prevalece sobre las notas de solución S02. Las recomendaciones y ejemplos de S02 no se convierten automáticamente en restricciones. Prioridades MoSCoW: M obligatoria para la línea base, S conveniente y C opcional. Todos los requisitos están propuestos para aprobación; origen E significa confirmado en el texto, no aprobado por un patrocinador real.

## Fuera de alcance salvo aprobación

Reemplazar el Core o el IdP, desarrollar un libro contable nuevo, créditos, inversiones, pagos internacionales, tarjetas y almacenamiento de PAN, servicio propio de certificación electrónica, motor de IA generativa y rediseño integral de los reportes regulatorios. Los pagos de servicios públicos o privados son una posible extensión que necesita aclaración del término pagos en el ejercicio.

## Contenido

|                                                 |   |
|-------------------------------------------------|---|
| Base de uso.....                                | 1 |
| 1 Alcance y criterios de interpretación .....   | 2 |
| Alcance del producto.....                       | 2 |
| Alcance regulatorio .....                       | 2 |
| Jerarquía de fuentes.....                       | 2 |
| Fuera de alcance salvo aprobación .....         | 2 |
| Contenido .....                                 | 2 |
| 2 Requisitos y restricciones del ejercicio..... | 6 |

3 Aplicación de BABOK y gobierno .....7

    Modelo de conceptos del negocio .....7

    Responsabilidad de aprobación .....7

4 Requisitos de negocio y de interesados .....8

    Necesidades de interesados.....8

5 Requisitos funcionales de consulta y operaciones .....9

    RF01 Consulta de productos.....9

    RF02 Histórico de movimientos .....9

    RF03 Consulta de detalle.....9

    RF04 Transferencia entre cuentas propias.....9

    RF05 Transferencia interbancaria .....9

    RF06 Pagos.....9

6 Requisitos funcionales de identidad y seguridad ..... 10

    RF07 Confirmación y comprobante..... 10

    RF08 Idempotencia y seguimiento ..... 10

    RF09 Límites y autorización ..... 10

    RF10 Onboarding facial ..... 10

    RF11 Vinculación de identidad ..... 10

    RF12 Acceso posterior..... 10

7 Requisitos funcionales de integración y evidencia..... 11

    RF13 Recuperación de acceso ..... 11

    RF14 Notificaciones con dos sistemas..... 11

    RF15 Registro de acciones del cliente ..... 11

    RF16 Capa de integración..... 11

    RF17 Persistencia para consultas frecuentes..... 11

    RF18 Conciliación y excepciones ..... 11

8 Requisitos funcionales de cumplimiento ..... 12

    RF19 Prevención de fraude y lavado ..... 12

    RF20 Información y derechos de datos ..... 12

    RF21 Bases de legitimación ..... 12

    RF22 Gestión de vulneraciones ..... 12

    RF23 Evidencia y reportes regulatorios..... 12

    RF24 Documentos tributarios ..... 12

9 Requisitos no funcionales de protección ..... 13

    RNF01 Autorización de extremo a extremo ..... 13

    RNF02 Protección criptográfica..... 13

RNF03 Integridad de auditoría ..... 13

RNF04 Privacidad desde el diseño..... 13

RNF05 Seguridad de aplicaciones..... 13

10 Requisitos no funcionales de continuidad..... 14

    RNF06 Disponibilidad ..... 14

    RNF07 Tolerancia a fallos ..... 14

    RNF08 Recuperación ante desastres..... 14

    RNF09 Copias y restauración..... 14

    RNF10 Auto healing..... 14

    RNF11 Resiliencia de dependencias ..... 14

11 Requisitos no funcionales de calidad y operación ..... 15

    RNF12 Latencia y carga..... 15

    RNF13 Escalabilidad y desacoplamiento ..... 15

    RNF14 Observabilidad y operación ..... 15

    RNF15 Conservación y entrega de evidencia ..... 15

    RNF16 Usabilidad y accesibilidad ..... 15

    RNF17 Despliegues y costos ..... 15

12 Transición reglas e interfaces ..... 16

    Reglas de negocio propuestas ..... 16

    Contratos e interfaces exigibles ..... 16

13 Matriz normativa bancaria ecuatoriana ..... 17

14 Matriz de datos personales biometría e IA ..... 18

15 Cobertura complementaria y estándares..... 19

    Ámbitos adicionales sujetos a aplicabilidad ..... 19

    Estándares y prácticas seleccionados..... 19

    Cierre del inventario legal ..... 19

16 Decisiones candidatas y justificación ..... 20

17 Matriz de trazabilidad y entrega de arquitectura ..... 21

    Requisitos de los entregables C4..... 21

18 Validación pendientes y criterios de aprobación ..... 22

    Preguntas que deben cerrarse ..... 22

    Plan de aceptación ..... 22

    Correcciones de las notas de referencia ..... 22

19 Fuentes y control de verificación ..... 23

19 Fuentes y control de verificación continuación..... 24

    Registro de versión ..... 24



## 2 Requisitos y restricciones del ejercicio

| ID y fuente    | Exigencia y criterio de cobertura                                                                                                                                                    |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| E01 • p 1      | Consultar histórico, transferir y pagar entre cuentas propias e interbancarias. Cubrir flujos exitosos y fallidos.                                                                   |
| E02 • p 1      | Obtener datos de dos sistemas: Core para datos básicos, movimientos y productos; sistema independiente para detalle.                                                                 |
| E03 • p 2      | Integrar como mínimo dos sistemas de notificación propios o externos y avisar sobre movimientos.                                                                                     |
| E04 • p 2      | Dos frontales: SPA y móvil con framework multiplataforma. Comparar al menos dos opciones móviles y justificar la elegida.                                                            |
| E05 • p 2      | Reutilizar el producto corporativo OAuth 2.0; recomendar el flujo. No implementar un IdP desde cero.                                                                                 |
| E06 • p 2      | Onboarding móvil con reconocimiento facial y relación con autorización y autenticación; definir acceso posterior.                                                                    |
| E07 • p 2      | Base de auditoría para todas las acciones del cliente. Persistencia para clientes frecuentes mediante patrones e interacción de componentes.                                         |
| E08 • pp 2–3   | Capa de integración con API Gateway y tres servicios iniciales: datos básicos, movimientos y transferencias. Se admiten servicios adicionales.                                       |
| E09 • p 3      | HA, tolerancia a fallos, DR, seguridad, monitoreo, excelencia operativa y auto-healing.                                                                                              |
| E10 • p 3      | Nube AWS o Azure opcional si resulta necesaria; existe presupuesto, pero se evalúa manejo de costos. Baja latencia.                                                                  |
| E11 • p 3      | Favorecer desacoplamiento, reutilización y cohesión; permitir extensiones.                                                                                                           |
| E12 • pp 1 y 3 | Entregar C4 de contexto, contenedores y componentes. Infraestructura con herramienta y representación a elección.                                                                    |
| E13 • pp 1 y 4 | Cada decisión debe justificarse; se valora un mínimo de dos fundamentos teóricos por decisión y alternativas evaluadas.                                                              |
| E14 • pp 3–4   | Incluir regulación financiera y estándares de seguridad. Rúbrica incluye integración, frontales, acceso a datos, nube, costos, autenticación, onboarding, auditoría, HA y monitoreo. |

No se fijan en S01: nube obligatoria, Kubernetes, lenguaje backend, motor de base de datos, proveedor biométrico, región, volumen, SLA numérico, RTO/RPO, plazo de retención, umbrales AML ni presupuesto máximo. No deben presentarse como restricciones del enunciado.

### 3 Aplicación de BABOK y gobierno

Se aplican las seis áreas de conocimiento mediante actividades y productos verificables. La clasificación distingue requisitos de negocio, interesados, solución y transición; RF y RNF pertenecen a solución. [S03]

| Área                             | Aplicación en BP y evidencia                                                                                                                    |
|----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------|
| Planificación y monitoreo        | Definir responsables, alcance, revisores, prioridades, atributos y registro de decisiones.                                                      |
| Elicitación y colaboración       | Analizar S01; realizar talleres con negocio, Core, IdP, operaciones, DPD y Cumplimiento; confirmar ambigüedades del apartado 18.                |
| Ciclo de vida de requisitos      | Mantener IDs, origen, dependencias, pruebas y control de cambios. Aprobar una línea base antes de diseñar en detalle.                           |
| Análisis de estrategia           | Necesidad: canal digital seguro. Estado actual: Core, detalle e IdP existentes. Estado futuro: servicios desacoplados con operación resiliente. |
| Análisis y definición del diseño | Especificar RF/RNF, escenarios, reglas, interfaces, modelos C4 y alternativas en ADR.                                                           |
| Evaluación de la solución        | Medir SLI, resultados de aceptación, incidentes y costo por transacción; comparar con objetivos y acordar mejoras.                              |

#### Modelo de conceptos del negocio

Necesidad: operar sin atención presencial. Cambio: incorporar banca por internet y móvil. Solución: canal integrado con sistemas de registro. Valor: acceso, confianza y capacidad de crecimiento. Interesados: clientes y áreas de BP. Contexto: regulación ecuatoriana, dependencias corporativas y terceros.

#### Responsabilidad de aprobación

| Rol                               | Responsabilidad                                                                |
|-----------------------------------|--------------------------------------------------------------------------------|
| Producto y patrocinador           | Validar valor, alcance, prioridad y criterios funcionales.                     |
| Arquitectura y dueños de sistemas | Aprobar restricciones, contratos, capacidad y decisiones técnicas.             |
| Seguridad y DPD                   | Validar amenazas, protección de datos, biometría, IA y controles de acceso.    |
| Cumplimiento y Legal              | Validar matriz normativa, KYC, PLA/FT, reportes, conservación y contratos.     |
| Riesgos y Operaciones             | Aprobar BIA, continuidad, SLO y procedimientos de recuperación.                |
| QA y Auditoría                    | QA produce evidencia; Auditoría revisa independencia e integridad del control. |

Cambio propuesto → análisis de impacto en requisitos, normativa, costos y C4 → decisión del propietario y revisores afectados → nueva versión → pruebas y comunicación. No se declara una aprobación ni una entrevista que no haya ocurrido.

## 4 Requisitos de negocio y de interesados

| ID   | Necesidad y resultado verificable                                                                                                                    | Trazabilidad |
|------|------------------------------------------------------------------------------------------------------------------------------------------------------|--------------|
| RN01 | Permitir autoservicio para histórico, transferencias y pagos desde ambos canales; los casos críticos de aceptación deben aprobarse antes del piloto. | E01 E04      |
| RN02 | Reutilizar Core, detalle e IdP corporativos; cada integración tendrá contrato y propietario identificado.                                            | E02 E05 E08  |
| RN03 | Conservar confianza y evidencia operativa; todas las operaciones de prueba deben reconstruirse desde solicitud hasta resultado y notificación.       | E03 E07 E14  |
| RN04 | Sostener operación ante fallos y crecimiento; aprobar pruebas de carga, conmutación y recuperación definidas en RNF.                                 | E09 E11      |
| RN05 | Incorporar clientes mediante onboarding seguro y tratamiento lícito de biometría; no activar cuentas de canal sin decisión de identidad aprobada.    | E06 N03 N06  |
| RN06 | Controlar inversión y operación; comparar costo total de alternativas y medir costos del canal antes de escalar.                                     | E10 rúbrica  |

### Necesidades de interesados

| ID y actor            | Requisito del interesado                                                                      | RF y RNF asociados |
|-----------------------|-----------------------------------------------------------------------------------------------|--------------------|
| RI01 Cliente habitual | Consultar solo sus productos y operar con información clara sobre estado, costos y resultado. | RF01–09 RNF01      |
| RI02 Nuevo cliente    | Completar alta facial, conocer uso de datos y disponer de atención si la validación falla.    | RF10–12 RF20       |
| RI03 Operaciones      | Identificar estados inciertos, conciliar y recuperar sin duplicar cargos.                     | RF08 RF18 RNF06–08 |
| RI04 Seguridad y DPD  | Controlar accesos, evidenciar tratamiento y atender incidentes y derechos.                    | RF20–22 RNF01–04   |
| RI05 Cumplimiento     | Gestionar alertas y evidencia regulatoria con reserva y revisión autorizada.                  | RF19 RF23 RNF15    |
| RI06 Auditoría        | Reconstruir quién hizo qué, cuándo, con qué resultado y referencia de operación.              | RF15 RNF03 RNF15   |
| RI07 Desarrollo y TI  | Extender dominios mediante contratos estables, observabilidad y despliegues reproducibles.    | RF16 RNF10–14      |

Métricas de adopción, conversión de onboarding y reducción de atención presencial se fijarán con datos reales de BP. No se inventa un porcentaje de mejora del negocio.

## 5 Requisitos funcionales de consulta y operaciones

### RF01 Consulta de productos

Origen: E01 E02 | Prioridad: M | Responsable: Producto

El sistema deberá mostrar los productos habilitados del cliente autenticado mediante el Core.

Aceptación: Prueba positiva muestra los productos esperados; cambiar el identificador por el de otro cliente devuelve denegación sin datos.

### RF02 Histórico de movimientos

Origen: E01 E08 | Prioridad: M | Responsable: Producto

El sistema deberá consultar movimientos por cuenta y rango de fechas con paginación y orden estable.

Aceptación: Comparar con un conjunto de referencia del Core; todas las páginas contienen los registros esperados sin omisiones ni duplicados.

### RF03 Consulta de detalle

Origen: E02 | Prioridad: M | Responsable: Dueño de datos

El sistema deberá obtener del sistema independiente los atributos detallados necesarios y aplicar precedencia explícita por campo.

Aceptación: Un caso con datos divergentes respeta la matriz de autoridad; una falla de detalle se informa sin inventar valores.

### RF04 Transferencia entre cuentas propias

Origen: E01 | Prioridad: M | Responsable: Producto

El sistema deberá permitir transferencias entre cuentas habilitadas del mismo cliente, previa validación y confirmación.

Aceptación: Con saldo suficiente registra una sola operación en Core; con saldo insuficiente o cuenta no propia no genera débito.

### RF05 Transferencia interbancaria

Origen: E01 E08 | Prioridad: M | Responsable: Pagos

El sistema deberá enviar la orden al mecanismo interbancario contratado y conservar su referencia y estado.

Aceptación: Pruebas de aceptación, rechazo y timeout muestran estados distintos; un acuse de recepción no se presenta como liquidación final.

### RF06 Pagos

Origen: E01 | Prioridad: M | Responsable: Producto

El sistema deberá procesar pagos mediante el servicio autorizado para el tipo de obligación y destino.

Aceptación: Cada tipo de pago aprobado tiene caso exitoso, rechazo y conciliación. Catálogo exacto de obligaciones pendiente en Q01.

## 6 Requisitos funcionales de identidad y seguridad

### RF07 Confirmación y comprobante

Origen: D de E01 | Prioridad: M | Responsable: Producto

El sistema deberá mostrar origen, destino enmascarado, monto, moneda y cargos aplicables antes de confirmar y emitir comprobante con estado.

Aceptación: Los datos confirmados coinciden con la orden persistida; el comprobante indica identificador, fecha y estado real.

### RF08 Idempotencia y seguimiento

Origen: D de E01 E09 | Prioridad: M | Responsable: Pagos

El sistema deberá identificar solicitudes repetidas y permitir consultar el estado de la operación original.

Aceptación: Reenviar 10 veces la misma clave y contenido produce un solo efecto financiero; misma clave con contenido distinto se rechaza.

### RF09 Límites y autorización

Origen: D N01 N02 | Prioridad: M | Responsable: Riesgos

El sistema deberá validar titularidad, permisos, límites y reglas transaccionales antes de ordenar el débito.

Aceptación: Una prueba por regla deniega la operación no permitida; alterar datos de la orden invalida la autorización previa.

### RF10 Onboarding facial

Origen: E06 N03 N06 | Prioridad: M | Responsable: Onboarding y DPD

La app deberá integrar verificación facial y decisión de identidad, con prueba de vida propuesta y derivación controlada de excepciones.

Aceptación: Identidad verificada permite continuar; suplantación simulada o resultado inconcluso no activa acceso; se conserva referencia de la evaluación.

### RF11 Vinculación de identidad

Origen: E05 E06 | Prioridad: M | Responsable: Identidad

El sistema deberá vincular una identidad aprobada con un único sujeto del IdP y el cliente del Core mediante identificadores estables.

Aceptación: Repetir la confirmación de onboarding no crea identidades duplicadas ni permite vincular otro cliente.

### RF12 Acceso posterior

Origen: E05 E06 P | Prioridad: M | Responsable: Identidad

El sistema deberá reutilizar el IdP con OpenID Connect sobre OAuth 2.0 y Authorization Code con PKCE; habilitar clave con MFA o passkey si el producto lo soporta.

Aceptación: Pruebas cubren ingreso, MFA, expiración, cierre y revocación. La biometría local desbloquea una credencial; no se envía la huella al backend. [S17]

## 7 Requisitos funcionales de integración y evidencia

### RF13 Recuperación de acceso

Origen: D de E05 E06 | Prioridad: M | Responsable: Identidad y Seguridad

El sistema deberá recuperar acceso y revocar dispositivos mediante verificación de identidad con nivel de control equivalente al acceso protegido.

Aceptación: Un atacante sin evidencia suficiente no recupera la cuenta; una recuperación válida invalida credenciales afectadas y genera aviso y auditoría.

### RF14 Notificaciones con dos sistemas

Origen: E03 | Prioridad: M | Responsable: Operaciones

El sistema deberá integrar al menos dos sistemas de envío mediante adaptadores y registrar cada intento y resultado.

Aceptación: Deshabilitar el sistema primario activa el alterno según política; el aviso corresponde al evento real, sin duplicar el movimiento financiero.

### RF15 Registro de acciones del cliente

Origen: E07 | Prioridad: M | Responsable: Auditoría y Seguridad

El sistema deberá registrar en la base de auditoría consultas, cambios, accesos y operaciones, incluyendo intentos fallidos y denegados.

Aceptación: Para cada acción del catálogo se verifica actor, fecha, acción, objeto enmascarado, resultado y correlación; no contiene claves, OTP ni biometría cruda.

### RF16 Capa de integración

Origen: E08 | Prioridad: M | Responsable: Arquitectura

El sistema deberá canalizar el acceso a servicios mediante API Gateway y mantener separados contratos de datos básicos, movimientos y transferencias.

Aceptación: Pruebas verifican enrutamiento, autenticación, autorización y rechazo de accesos externos directos a servicios protegidos.

### RF17 Persistencia para consultas frecuentes

Origen: E07 P | Prioridad: M | Responsable: Arquitectura de datos

El sistema deberá reutilizar información permitida de clientes frecuentes mediante Cache Aside y una política explícita de vigencia e invalidación.

Aceptación: Una lectura repetida reduce llamados a origen; al actualizar un dato se invalida su copia. Un saldo en caché nunca autoriza un débito.

### RF18 Conciliación y excepciones

Origen: D de E01 E09 | Prioridad: M | Responsable: Operaciones de pagos

El sistema deberá conciliar su estado con Core y red de pagos y derivar discrepancias a una bandeja autorizada.

Aceptación: Un timeout posterior al débito se resuelve consultando el estado; no se reenvía ni compensa a ciegas una operación potencialmente liquidada.

## 8 Requisitos funcionales de cumplimiento

### RF19 Prevención de fraude y lavado

Origen: N07 D | Prioridad: M | Responsable: Cumplimiento y Riesgos

El sistema deberá suministrar eventos y datos necesarios a los controles corporativos de fraude y PLA/FT, con reglas versionadas y decisiones trazables.

Aceptación: Un escenario de alerta crea caso y evidencia; solo roles autorizados pueden revisar o resolver. No se presupone un proveedor externo obligatorio.

### RF20 Información y derechos de datos

Origen: N03 N04 | Prioridad: M | Responsable: DPD

El sistema deberá presentar avisos de privacidad y registrar solicitudes de derechos con identidad verificada y seguimiento.

Aceptación: El titular recibe constancia y respuesta trazable; la supresión respeta retenciones legales y comunica su fundamento cuando no procede.

### RF21 Bases de legitimación

Origen: N03 N04 | Prioridad: M | Responsable: DPD y Legal

El sistema deberá registrar la base aplicable por finalidad y las versiones de avisos y consentimientos cuando correspondan.

Aceptación: La evidencia permite identificar finalidad, base, versión y momento; retirar consentimiento de marketing no desactiva automáticamente un tratamiento legalmente obligatorio.

### RF22 Gestión de vulneraciones

Origen: N03 N06 | Prioridad: M | Responsable: Seguridad y DPD

El sistema deberá apoyar registro, evaluación y seguimiento de incidentes con datos personales y conservar evidencia de las notificaciones exigibles.

Aceptación: Un simulacro genera expediente, responsables, evaluación, destinatarios y vencimientos conforme al procedimiento normativo validado. No se presume un único plazo universal.

### RF23 Evidencia y reportes regulatorios

Origen: N01 N07 | Prioridad: M | Responsable: Cumplimiento

El sistema deberá entregar al proceso corporativo autorizado la información del canal necesaria para reportes y requerimientos de autoridad.

Aceptación: Un conjunto de prueba se exporta con integridad, trazabilidad y acceso restringido; Cumplimiento valida esquema, plazo y acuse del canal autorizado.

### RF24 Documentos tributarios

Origen: N09 condicional | Prioridad: M si aplica | Responsable: Tributario

Si una operación o comisión requiere documento tributario, el canal deberá integrarse con el emisor corporativo y permitir recuperarlo.

Aceptación: Un caso gravado o sujeto a retención obtiene el documento exigible y estado del emisor. El recibo de una transferencia no se trata automáticamente como factura.

## 9 Requisitos no funcionales de protección

Las tecnologías y umbrales siguientes son propuestas de control, salvo exigencia expresa identificada. La obligación legal es el resultado protegido; una norma no impone automáticamente una marca o algoritmo concreto.

### RNF01 Autorización de extremo a extremo

Origen: E09 N01 N03 | Prioridad: M | Responsable: Seguridad

Cada servicio deberá verificar identidad, alcance y propiedad del recurso; las funciones administrativas tendrán segregación de permisos.

Aceptación: El 100 % de pruebas negativas de acceso entre clientes y elevación de privilegios debe ser rechazado.

### RNF02 Protección criptográfica

Origen: E09 N03 P | Prioridad: M | Responsable: Seguridad

Se deberá cifrar información sensible en tránsito y reposo con gestión central de claves y rotación. Perfil propuesto TLS 1.2 robusto o superior, preferencia 1.3.

Aceptación: Escaneo rechaza protocolos inseguros; secretos no aparecen en código ni logs; restauración y rotación se prueban sin exposición de claves.

### RNF03 Integridad de auditoría

Origen: E07 N01 P | Prioridad: M | Responsable: Auditoría

Se deberá impedir modificación o borrado no autorizado de eventos y conservar evidencia de integridad bajo política de retención.

Aceptación: Un administrador de aplicación no altera evidencias; intentos quedan registrados. Archivo WORM, si se adopta, demuestra configuración efectiva y recuperación.

### RNF04 Privacidad desde el diseño

Origen: N03 N04 | Prioridad: M | Responsable: DPD

Cada flujo deberá limitar datos por finalidad, acceso y plazo; pruebas y telemetría usarán datos sintéticos o debidamente protegidos.

Aceptación: Revisión de flujos, permisos y datos confirma ausencia de campos innecesarios y ejecución de borrado o bloqueo según política.

### RNF05 Seguridad de aplicaciones

Origen: E09 P | Prioridad: M | Responsable: Seguridad y QA

Se deberá verificar web, API y móvil con un perfil acordado de OWASP ASVS, API Security y MASVS y pruebas de penetración.

Aceptación: No quedan vulnerabilidades críticas o altas explotables sin tratamiento y decisión formal de riesgo antes de producción; dependencias y artefactos son trazables.

## 10 Requisitos no funcionales de continuidad

Metas iniciales para negociación con BP, no valores contenidos en S01 ni mínimos legales universales. El BIA debe confirmar su viabilidad para Core, IdP, comunicaciones y terceros.

### RNF06 Disponibilidad

Origen: E09 P | Prioridad: M | Responsable: Operaciones

El servicio de consultas y recepción de órdenes deberá alcanzar 99,95 % mensual de disponibilidad observada de extremo a extremo.

Aceptación: Sondas y solicitudes válidas miden el SLI por capacidad. En 30 días, presupuesto máximo de indisponibilidad: 21,6 minutos; incluir mantenimientos. Liquidación externa se mide aparte.

### RNF07 Tolerancia a fallos

Origen: E09 P | Prioridad: M | Responsable: Arquitectura y Operaciones

La pérdida de una instancia o zona no deberá causar pérdida de órdenes confirmadas ni duplicación financiera.

Aceptación: Inyección de fallos durante carga confirma continuidad mediante capacidad redundante y reconciliación; todos los IDs afectados tienen estado explicable.

### RNF08 Recuperación ante desastres

Origen: E09 P | Prioridad: M | Responsable: Continuidad

El canal tendrá RTO propuesto de 60 minutos y RPO de 5 minutos para datos operativos replicables; ninguna orden financiera confirmada podrá quedar sin reconstrucción.

Aceptación: Simulacro regional mide restauración y conciliación con Core y eventos durables. Si no puede demostrarse recuperación de órdenes confirmadas, se prohíbe confirmar durante ese modo de fallo.

### RNF09 Copias y restauración

Origen: E09 P | Prioridad: M | Responsable: Infraestructura

Se deberán mantener copias cifradas, aisladas y verificadas con política de retención por conjunto de datos.

Aceptación: Restauración trimestral propuesta en ambiente aislado satisface integridad y tiempos; se prueba recuperación tras borrado o corrupción, no solo failover.

### RNF10 Auto healing

Origen: E09 P | Prioridad: M | Responsable: Operaciones

Se deberán detectar y reemplazar instancias no saludables con límites que eviten ciclos de reinicio y nuevos efectos financieros.

Aceptación: Prueba elimina una instancia; detección y reposición propuestas en menos de 5 minutos. El proceso no confirma, reenvía ni revierte pagos sin verificar su estado.

### RNF11 Resiliencia de dependencias

Origen: E09 P | Prioridad: M | Responsable: Arquitectura

Las llamadas tendrán timeout, aislamiento de recursos, circuit breaker y reintentos limitados solo cuando sean seguros.

Aceptación: Caída de detalle, notificador o Core no agota todos los recursos; se devuelve estado controlado y se conservan tareas pendientes con deduplicación.

## 11 Requisitos no funcionales de calidad y operación

### RNF12 Latencia y carga

Origen: E10 P | Prioridad: M | Responsable: Arquitectura y QA

Bajo carga inicial propuesta de 100 solicitudes por segundo y 1 000 sesiones, consultas tendrán  $p95 \leq 2$  s y acuse durable de orden  $p95 \leq 3$  s.

Aceptación: Prueba de 60 minutos con mezcla 80 % consultas y 20 % órdenes, datos representativos y red desde Ecuador. No confundir acuse con liquidación externa; ajustar carga en Q03.

### RNF13 Escalabilidad y desacoplamiento

Origen: E11 P | Prioridad: M | Responsable: Arquitectura

Los dominios deberán exponerse por contratos versionados y escalar según su carga sin acceso directo a bases de otros dominios.

Aceptación: Duplicar carga de consulta permite escalar su capacidad; pruebas contractuales mantienen transferencias y evitan degradación no controlada del Core.

### RNF14 Observabilidad y operación

Origen: E09 P | Prioridad: M | Responsable: Operaciones

Se deberán correlacionar métricas, trazas y logs sin secretos, con alertas y procedimientos de atención.

Aceptación: Cada operación de prueba se localiza por correlación; una falla crítica genera alerta en  $\leq 2$  minutos propuestos y tiene responsable y runbook.

### RNF15 Conservación y entrega de evidencia

Origen: N01 N03 N07 | Prioridad: M | Responsable: Legal y Auditoría

Se deberá aplicar una tabla de retención por clase de dato, con fundamento, disparador, custodia, bloqueo legal y eliminación.

Aceptación: Auditoría recupera muestras durante el plazo aprobado; el vencimiento elimina datos autorizados y conserva los sujetos a obligación o litigio.

### RNF16 Usabilidad y accesibilidad

Origen: D P | Prioridad: M | Responsable: Producto y QA

Se deberá permitir completar tareas esenciales con mensajes comprensibles, navegación accesible y alternativa de atención.

Aceptación: Pruebas de teclado y lector de pantalla para web y ayudas nativas móviles; objetivo WCAG 2.2 AA acordado. Errores no exponen detalles técnicos.

### RNF17 Despliegues y costos

Origen: E09 E10 P | Prioridad: M | Responsable: TI y Finanzas

Se deberán desplegar artefactos reproducibles con reversión y registrar costo por ambiente y capacidad.

Aceptación: Prueba de rollback sin corromper datos; estimación mensual incluye HA, DR, egreso, licencias, biometría y mensajes, con alertas al 80 % y 100 % del presupuesto aprobado.

## 12 Transición reglas e interfaces

| ID   | Requisito de transición y aceptación                                                                                                                   | Responsable |
|------|--------------------------------------------------------------------------------------------------------------------------------------------------------|-------------|
| RT01 | Configurar IdP y clientes OAuth sin migrar credenciales innecesariamente. Aceptación: federación, altas y recuperación aprobadas en entorno integrado. | Identidad   |
| RT02 | Homologar Core, detalle, red de pagos, biometría y dos notificadores. Aceptación: contratos, datos de prueba y fallos verificados.                     | Integración |
| RT03 | Aprobar BIA, runbooks, guardias y escalamiento. Aceptación: simulacro de incidente y DR con evidencia y responsables.                                  | Operaciones |
| RT04 | Preparar pilotos, capacitación y soporte. Aceptación: usuarios y mesa de ayuda completan flujos y conocen reversión del despliegue.                    | Producto    |
| RT05 | Validar contratos, EIPD, matriz legal y retención antes del uso real de datos. Aceptación: aprobaciones de responsables de control.                    | Legal y DPD |
| RT06 | Cargar configuración y reconciliar datos iniciales. Aceptación: conteos y muestras concordantes; no se copia el histórico completo sin necesidad.      | Datos       |

### Reglas de negocio propuestas

RB01 El Core conserva la autoridad sobre saldos y contabilización. RB02 Una orden no se marca completada por haber sido recibida. RB03 Un timeout significa resultado desconocido hasta consultar o conciliar. RB04 No se compensa automáticamente un pago irrevocable o ya liquidado. RB05 Preferencias comerciales no suprimen alertas obligatorias. RB06 Los cambios de límites, contactos y credenciales requieren control reforzado. RB07 Los datos biométricos no se reutilizan para otros fines sin base jurídica válida.

### Contratos e interfaces exigibles

IF01 Core y detalle: identificador de cliente, autoridad por campo, paginación, fechas, errores y capacidad. IF02 IdP: emisor, audiencia, scopes, redirecciones, PKCE y revocación. IF03 Pagos: formato contratado, estados, idempotencia, calendario, conciliación y autenticación mutua cuando aplique. IF04 Biometría: sesión, finalidad, evidencia de decisión, retención y borrado. IF05 Notificaciones: evento, destino validado, estado, reintentos y acuse. IF06 Auditoría: event ID, actor, hora UTC, acción, resultado y correlación.

Todos los contratos deberán especificar propietario, versión, seguridad, límites, disponibilidad, tratamiento de datos y comportamiento ante fallos. No se impone ISO 20022 al SPI sin confirmar el contrato técnico de BP.

### 13 Matriz normativa bancaria ecuatoriana

Aplicabilidad al canal, con corte de revisión al 29 de septiembre de 2026. V significa fuente oficial o publicación identificada; C exige verificar texto consolidado, artículos o implementación antes de la línea base regulatoria. Un registro V no certifica cumplimiento de BP.

| ID y norma               | Aplicación y evidencia exigible                                                                                                                                                                                                                                | Requisitos y estado                                      |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------|
| N01 Constitución y COMF  | Protección de datos y privacidad; derechos del usuario financiero, reserva bancaria y operación autorizada. COMF arts 103–108: pagos, irrevocabilidad y soporte documental según referencia BCE. Matriz de permisos, evidencia y proceso de reclamo. [S05 S09] | RF07–09 RF15 RF23<br>RNF01 RNF15<br>V/C consolidación    |
| N02 Normas SB            | Gestión de riesgos, riesgo operativo, seguridad, continuidad, canales electrónicos, terceros, auditoría y protección del usuario. Usar codificación vigente. SB-2021-2126 es antecedente identificado, no prueba de texto consolidado actual. [S06]            | RF09 RF14–15<br>RNF01–11 RNF14<br>C artículos y reformas |
| N07 PLA y FT             | Ley Orgánica de Prevención, Detección y Combate del Delito de Lavado de Activos y de la Financiación de Otros Delitos; regulación bancaria y UAFE aplicable. KYC, monitoreo, reserva y reportes a cargo de Cumplimiento. [S10]                                 | RF10 RF19 RF23<br>RNF15<br>V/C alcance y plazos          |
| N08 Sistema de pagos     | COMF; normas JPRM-2022-020-M y JPRM-2024-008-M referidas por BCE; responsabilidades BCE-GG-052-2018 y participantes BCE-GG-007-2021. Confirmar convenio y mecanismo realmente usado. [S09]                                                                     | RF05 RF08 RF18<br>IF03<br>V/C contrato                   |
| N09 Régimen tributario   | LRTI, reglamento, comprobantes electrónicos, retenciones e información fiscal según producto. SRI identifica a instituciones financieras en grupos obligados de emisión. Un débito no exige por sí solo factura. [S11]                                         | RF24 condicional<br>V/C por operación                    |
| N10 Comercio electrónico | Ley de Comercio Electrónico, Firmas Electrónicas y Mensajes de Datos y reglamento: evidencia digital y contratación; distinguir aceptación, autenticación y firma electrónica. [S12]                                                                           | RF07 RF11 RF15<br>RNF03 RNF15<br>V/C acto concreto       |

Las normas de prevención no se modelan como una autorización síncrona de UAFE para cada transferencia. La entidad define controles y remite reportes por sus procesos autorizados. El proveedor antifraude o biométrico puede ser propio o contratado según evaluación y requisitos aplicables.

## 14 Matriz de datos personales biometría e IA

| ID y marco                | Aplicación y evidencia                                                                                                                                                                                                                   | Requisitos                        |
|---------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------|
| N03 LOPDP y RGLOPDP       | LOPDP de 2021 y Reglamento General Decreto 904 de 2023. Inventario de tratamientos, bases, derechos, seguridad, EIPD y transferencias. Art 10: principios; art 20: decisiones automatizadas, corroborados en norma SPDP de IA. [S05 S07] | RF20–22<br>RNF02–04 RNF15<br>RT05 |
| N04 Normativa SPDP        | Revisar contratos 2025-0006-R, DPD 2025-0028-R, eliminación 2025-0030-R e interés legítimo 2025-0041-R. Aplicabilidad por finalidad y rol, sin usar consentimiento genérico. [S07]                                                       | RF20 RF21<br>RNF04 RNF15          |
| N05 Nube y transferencias | Resolución 2026-0004-R sobre transferencias y comunicaciones. Identificar países, encargados y subencargados; calificar jurídicamente cada flujo y garantía. Evaluar también requisitos SB del servicio contratado. [S07]                | RNF02 RNF04<br>RT05 IF04–05       |
| N06 IA                    | Resolución SPDP-SPD-2026-0009-R y reforma 2026-0037-R publicada en RO 373 del 21 septiembre 2026. Exigir gestión de riesgos, EIPD cuando corresponda y mecanismos de derechos. No denominarla ley general de IA. [S08 S13]               | RF10 RF19 RF20<br>RNF04 RT05      |
| N06 Biométricos           | Resolución SPDP-SPD-2026-0039-R, publicación RO 376 del 24 septiembre 2026. Debe integrarse a la revisión del onboarding. El índice confirma publicación; cerrar revisión del articulado y transitorias antes del piloto. [S14]          | RF10–13<br>RNF04 RT05             |
| N06 Vulneraciones         | Resolución SPDP-SPD-2026-0040-R, Suplemento RO 376 del 24 septiembre 2026. Parametrizar obligaciones según destinatario, supuesto y cómputo validado. Pendiente revisión íntegra del articulado. [S15]                                   | RF22<br>RNF14 RT03                |
| N06 Riesgos y EIPD        | Guía SPDP 2026 y Resolución 2026-0012-R publicada en Suplemento RO 254. Usar versión 2026; no congelar la referencia en la guía 2025. [S16]                                                                                              | RF10 RF19<br>RNF04 RT05           |

Para IA, la reforma vincula obligaciones del encargado con acceso, visibilidad o control efectivo de datos, sin exoneración general. El contrato debe permitir a BP conocer limitaciones y controles relevantes. [S08] La publicación de las normas de biometría y vulneraciones está corroborada; sus plazos operativos y transitorios quedan como cierre documental específico.

# 15 Cobertura complementaria y estándares

## Ámbitos adicionales sujetos a aplicabilidad

| Ámbito                          | Tratamiento en el proyecto                                                                                                                                                                                              |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Usuario financiero y consumidor | Validar normas SB de información, tarifas, atención y reclamos, junto con la Ley Orgánica de Defensa del Consumidor en lo pertinente. RF07, RF20 y RNF16; matriz tarifaria y soporte aprobados.                         |
| COIP y evidencia                | Considerar delitos informáticos y financieros en el modelo de amenazas y custodia de evidencia. No convertir una tipificación penal en un algoritmo de detección obligatorio.                                           |
| Fintech y terceros auxiliares   | Verificar habilitación y régimen contractual cuando un proveedor actúe como servicio auxiliar o en actividad regulada. El uso de nube no transforma automáticamente a BP en otra clase de entidad.                      |
| Prudencial y contable           | Solvencia, liquidez, riesgo de crédito, contabilidad y seguro de depósitos permanecen en procesos corporativos. El canal entrega datos y evita inconsistencias; no calcula estos regímenes salvo ampliación de alcance. |
| SEPS                            | No es el supervisor base del supuesto banco privado. Si BP fuera cooperativa, reabrir la matriz y sustituir las normas sectoriales pertinentes.                                                                         |
| SRI y BCE                       | Integraciones condicionadas al producto y convenio. No agregar un llamado al SRI ni al BCE a cada acción del cliente sin proceso requerido.                                                                             |

## Estándares y prácticas seleccionados

ISO/IEC/IEEE 29148:2018 orienta especificación y trazabilidad. ISO/IEC 25010 orienta atributos de calidad; ISO/IEC 27001 y 27002, controles y SGSI; ISO 22301, continuidad; ISO/IEC 27017 y 27018, controles y privacidad en nube; ISO/IEC 27701, gestión de privacidad; ISO/IEC 42001, gobierno de IA, e ISO/IEC 30107-3, evaluación de ataques de presentación, son referencias a evaluar. No se declara que BP esté certificado ni que todas sean exigidas directamente por ley. [S04 S18]

OAuth 2.0 con OIDC y PKCE sustenta identidad; RFC 9700 aporta práctica de seguridad. OWASP ASVS y MASVS apoyan verificación; WCAG apoya accesibilidad. PCI DSS será aplicable por alcance de datos y ecosistema de tarjetas, no por el solo hecho de ser un banco. COBIT e ITIL pueden organizar gobierno y operación; no son leyes ecuatorianas. [S17–S20]

## Cierre del inventario legal

Legal y Cumplimiento deberán consolidar reformas y circulares por tipo de licencia, producto, tercero y fecha de salida. Cada fila N debe completarse con artículo vigente, responsable, evidencia, periodicidad y estado. Los ámbitos complementarios son controles de alcance para esa validación, no una declaración de revisión íntegra de todo su articulado.

## 16 Decisiones candidatas y justificación

Estas decisiones orientan el diseño posterior; no sustituyen requisitos. Cada ADR debe registrar alternativa, dos fundamentos, consecuencias, costo y prueba. Las selecciones son provisionales hasta validar capacidad y producto existente.

| ADR y propuesta                          | Alternativa y dos fundamentos                                                                                                                                                                         | Riesgo y requisitos                                                     |
|------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------|
| ADR01 Reusar IdP con Code y PKCE         | Alternativa: lógica propia, descartada por E05. Fundamentos: reutilización de control corporativo; PKCE protege el intercambio del código. Añadir OIDC para identidad.                                | Compatibilidad del IdP.<br>RF11–13                                      |
| ADR02 Móvil Flutter                      | Alternativa: React Native. Fundamentos: UI consistente entre plataformas; base compartida con integración nativa para credenciales. Comparar experiencia del equipo y SDK biométrico mediante prueba. | Plugins, accesibilidad y mantenimiento.<br>E04 RF10 RNF16               |
| ADR03 Dominios desacoplados              | Alternativa: monolito modular. Fundamentos: cambios aislados por capacidad; escalado diferencial de consultas y transacciones. Microservicios solo donde el beneficio compense operación distribuida. | Costo y observabilidad.<br>RNF13 RNF17                                  |
| ADR04 Cache Aside                        | Alternativa: lectura directa o modelo materializado. Fundamentos: menos presión sobre origen; copia descartable sin desplazar autoridad del Core. TTL e invalidación se prueban.                      | Datos obsoletos y privacidad.<br>RF17 RNF04                             |
| ADR05 Outbox y consumidores idempotentes | Alternativa: escritura dual síncrona. Fundamentos: estado y evento locales atómicos; reintento de entrega sin repetir efecto. La transacción local no incluye al Core.                                | Duplicados y desfase.<br>RF08 RF14–15                                   |
| ADR06 Orquestación de transferencias     | Alternativa: coreografía. Fundamentos: estado del flujo explícito; recuperación y conciliación centralizadas. Compensar solo operaciones reversibles y confirmadas.                                   | Timeout y pagos irrevocables.<br>RF05 RF18                              |
| ADR07 HA y DR en nube o híbrido          | Alternativa: solo sitio propio redundante. Fundamentos: separar fallos locales de desastre regional; automatizar aprovisionamiento y recuperación. Elegir AWS o Azure por mediciones y contratos.     | Latencia con Core, egreso y residencia.<br>RNF06–12                     |
| ADR08 Auditoría y archivo protegido      | Alternativa: logs mutables de aplicación. Fundamentos: separar permisos del operador; preservar evidencia verificable con retención. Mantener base de auditoría requerida y archivo si aporta valor.  | WORM debe configurarse, no inferirse del nombre de la BD.<br>RF15 RNF03 |

## 17 Matriz de trazabilidad y entrega de arquitectura

| Origen        | Requisitos                  | Evidencia de diseño y prueba                                                           |
|---------------|-----------------------------|----------------------------------------------------------------------------------------|
| E01 RN01 RI01 | RF01–09 RF18                | C4 consultas y pagos; pruebas de propiedad, saldo, rechazo, duplicados y conciliación. |
| E02 RN02      | RF01–03 RF17 IF01           | C4 Core y detalle; matriz de autoridad y contratos de integración.                     |
| E03 RN03      | RF14 RNF11 IF05             | Dos sistemas reales; prueba de fallo primario, reintentos y estado del aviso.          |
| E04 RN01      | RF01–14 RNF16 ADR02         | SPA y móvil visibles en C4 nivel 2; comparación de frameworks y prueba accesible.      |
| E05 RN02      | RF11–13 ADR01 IF02          | IdP existente y secuencia OIDC; pruebas de tokens, PKCE, revocación y recuperación.    |
| E06 RN05      | RF10–13 RF20–21 RT05        | Onboarding facial, relación con alta del IdP, EIPD y manejo de excepciones.            |
| E07 RN03      | RF15 RF17 RNF03 RNF15       | Base de auditoría y persistencia; patrones y pruebas de integridad e invalidación.     |
| E08 RN02      | RF16 IF01–06                | Gateway y tres servicios iniciales; contratos y pruebas de enrutamiento y errores.     |
| E09 RN04      | RNF01–11 RNF14 RNF17        | Despliegue HA/DR, amenazas, dashboards, runbooks y ensayos de fallos.                  |
| E10 RN06      | RNF12 RNF17 ADR07           | Medición desde Ecuador y comparación de costo total y escenarios de crecimiento.       |
| E11 RN04      | RNF13 ADR03–06              | Límites de dominio, contratos versionados y análisis de dependencias.                  |
| E12 E13       | ADR01–08 y entregables      | C4 niveles 1, 2 y 3 consistentes; ADR por cada decisión adicional.                     |
| E14 N01–10    | RF19–24 RNF01–05 RNF15 RT05 | Matriz regulatoria, controles verificables y revisión por responsables.                |

### Requisitos de los entregables C4

DE01 Contexto: BP como sistema, clientes y sistemas externos al límite; nombres, responsabilidades y relaciones comprensibles. DE02 Contenedores: SPA, móvil, servicios, almacenes y mensajería con tecnologías candidatas y protocolos. DE03 Componentes: detallar responsabilidades internas de contenedores críticos, especialmente transferencias, onboarding y auditoría; no confundir cada microservicio con componente interno. DE04 Infraestructura: fallos de zona y región, conectividad con Core y recuperación. DE05 ADR y costo: dos fundamentos por decisión y alternativas. Estos entregables se exigen al diseño; no se sustituyen con esta especificación.

## 18 Validación pendientes y criterios de aprobación

### Preguntas que deben cerrarse

| ID  | Decisión pendiente y dueño                                                                                            | Impacto        |
|-----|-----------------------------------------------------------------------------------------------------------------------|----------------|
| Q01 | Producto: clases de pagos, terceros del mismo banco, beneficiarios, comisiones y monedas.                             | RF05–07 RF24   |
| Q02 | BP y Legal: confirmar banco privado, licencias, alcance de terceros y normativa consolidada SB/UAFE.                  | N01 N02 N07    |
| Q03 | Negocio y TI: usuarios activos, transacciones pico, histórico, tamaño de respuesta y crecimiento.                     | RNF12 RNF17    |
| Q04 | Riesgos y Continuidad: BIA, SLA externo, RTO/RPO y presupuesto.                                                       | RNF06–09       |
| Q05 | Identidad: capacidades OI DC, PKCE, MFA, passkeys y revocación del producto.                                          | RF11–13        |
| Q06 | Datos: significado de persistencia de clientes frecuentes; caché propuesta o almacenamiento durable requerido.        | RF17 ADR04     |
| Q07 | Cumplimiento y Pagos: red interbancaria, contrato, finalización, límites y procedimiento de conciliación.             | RF05 RF09 RF18 |
| Q08 | DPD: texto íntegro, transitorias y plazos de normas SPDP 2026; bases para biometría, flujo internacional y retención. | RF10 RF20–22   |
| Q09 | Operaciones: dos sistemas de envío, independencia de fallos, destinos y plazo de entrega.                             | RF14 RNF11     |
| Q10 | Legal y Cumplimiento: plazos y esquema de reportes, conservación por clase y obligaciones SRI aplicables.             | RF23–24 RNF15  |

### Plan de aceptación

QA mantendrá un caso AC con el mismo número de cada RF y RNF, datos de entrada, resultado esperado, evidencia y ejecución. Producto valida funciones; Seguridad valida controles; Operaciones demuestra HA/DR; Cumplimiento y DPD aprueban los controles de su ámbito. La trazabilidad debe permitir ir de fuente a requisito, componente y prueba, y recorrer el camino inverso.

Criterio de salida: todos los M cuentan con evidencia satisfactoria; los condicionales tienen decisión de aplicabilidad; Q02, Q04, Q05, Q07, Q08 y Q10 están resueltos para producción; no quedan riesgos críticos sin tratamiento; están aprobados los contratos, la operación y la línea base. Una entrega de evaluación puede conservar supuestos explícitos y decisiones pendientes, sin afirmar cumplimiento productivo.

### Correcciones de las notas de referencia

No atribuir dos canales simultáneos a un artículo no corroborado. No prometer latencia total de 25 ms ni disponibilidad por decreto. No tratar DocumentDB como WORM por defecto. No equiparar OAuth con prueba de identidad. No revertir automáticamente tras timeout. No asumir que reguladores consumen cada transacción ni que SPI usa el protocolo ilustrado en un diagrama.

## 19 Fuentes y control de verificación

Fuentes consultadas el 29 de septiembre de 2026. Las referencias al ejercicio indican página del original. Las URLs permiten verificar el soporte; la versión consolidada y el encaje jurídico de cada control forman parte de la aprobación regulatoria.

S01 ejerciciopractico.docx, 4 páginas. Fuente primaria del reto; lectura completa.

Documento proporcionado por el usuario.

S02 notebook ejecicio practico.docx, 19 páginas. Notas de solución secundarias; no sustituyen S01.

Documento proporcionado por el usuario.

S03 IIBA, clasificación de requisitos y BABOK.

<https://www.iiba.org/knowledgehub/the-business-analysis-standard/4-implementing-business-analysis/4-4-understanding-requirements-and-designs/>

S04 ISO/IEC/IEEE 29148:2018, ficha oficial. Estructura adaptada; no se afirma conformidad cláusula por cláusula.

<https://www.iso.org/standard/72089.html>

S05 LOPDP, publicación de 2021 en repositorio público. Complementar con RGLOPDP Decreto 904 y consolidación jurídica.

[https://repositorio.consejodecomunicacion.gob.ec/handle/CONSEJO\\_REP/246](https://repositorio.consejodecomunicacion.gob.ec/handle/CONSEJO_REP/246)

S06 SB-2021-2126 y codificación SB. Resolución identificada; lectura íntegra y consolidación pendientes por acceso de la fuente.

<https://www.superbancos.gob.ec/bancos/wp-content/uploads/downloads/2021/12/resol-SB-2021-2126.pdf>

S07 SPDP, índice oficial de resoluciones 2024–2026. Identifica instrumentos; no sustituye revisión de articulado.

<https://spdp.gob.ec/resoluciones2/>

S08 SPDP, norma de IA y reforma de septiembre 2026. Texto de reforma consultado.

<https://spdp.gob.ec/wp-content/uploads/2026/02/ResolIA.pdf>

<https://spdp.gob.ec/wp-content/uploads/2026/09/SPDP-SPD-2026-0037-R.pdf>

S09 BCE, SPI: normas, participantes, convenios y operación; revisar contrato vigente de BP.

<https://www.bce.fin.ec/sistema-de-pagos/sistema-central-de-pagos/sistema-de-pagos-interbancarios-spi/>

S10 UAFE, biblioteca y ley de prevención. Identificación del marco; confirmar texto consolidado y normas específicas bancarias.

<https://www.uafe.gob.ec/biblioteca/>

## 19 Fuentes y control de verificación continuación

S11 SRI, instituciones financieras en grupos obligados a emitir comprobantes electrónicos.

<https://www.sri.gob.ec/contribuyentes-obligados-a-emitir-comprobantes-electronicos>

S12 Defensoría Pública, Ley de Comercio Electrónico y referencia a reforma 2021.

<https://biblioteca.defensoria.gob.ec/handle/37000/3374>

S13 Registro Oficial 373, 21 septiembre 2026. Publicación de reforma de IA.

<https://www.registroficial.gob.ec/registro-oficial-no-373-21/>

S14 Registro Oficial 376, 24 septiembre 2026. Norma de biometría 2026-0039-R. Publicación corroborada; articulado pendiente de revisión íntegra.

<https://www.registroficial.gob.ec/registro-oficial-no-376-16/>

S15 Suplemento RO 376, 24 septiembre 2026. Norma de vulneraciones 2026-0040-R. Publicación corroborada; articulado pendiente de revisión íntegra.

<https://www.registroficial.gob.ec/suplemento-no-376/>

S16 SPDP, Guía de gestión de riesgos 2026; RO 254 identifica Resolución 2026-0012-R.

<https://spdp.gob.ec/wp-content/uploads/2026/03/ggrisdp2026v2.pdf>

<https://www.registroficial.gob.ec/suplemento-no-254/>

S17 IETF, RFC 9700, buenas prácticas de seguridad OAuth 2.0.

<https://www.rfc-editor.org/rfc/rfc9700.html>

S18 ISO, catálogo de estándares para validación de ediciones y alcance de referencias complementarias.

<https://www.iso.org/standards.html>

S19 OWASP, ASVS y MASVS como referencias de verificación propuestas.

<https://owasp.org/www-project-application-security-verification-standard/>

<https://mas.owasp.org/MASVS/>

S20 W3C, WCAG 2.2; PCI SSC, alcance de estándares para tarjetas.

<https://www.w3.org/TR/WCAG22/>

<https://www.pcisecuritystandards.org/standards/>

### Registro de versión

1.0 • Especificación inicial basada en S01; clasificación BABOK, restricciones, 24 RF, 17 RNF, 6 requisitos de transición, trazabilidad, decisiones candidatas y matriz normativa con cierres documentales identificados.